

Access Control Policy

Organization: Rough Cut Manufacturing ("the Company"), operator of the WorkTrackPro application

Policy Owner: Jacob Rough, Chief Executive Officer — jacobrrough@gmail.com

Version: 1.0 **Effective Date:** June 17, 2026 **Next Review:** June 17, 2027

1. Purpose

This policy defines how Rough Cut Manufacturing controls access to its production systems and sensitive data so that only authorized individuals can reach the resources they need, and no more. It expands on §5 of the Information Security Policy.

2. Scope

Applies to all access to the WorkTrackPro application and its supporting systems — the Supabase database/auth/storage, Netlify hosting and functions, the GitHub repository, and the Plaid and QuickBooks Online provider dashboards — and to all employees, contractors, and service accounts.

3. Principles

- **Least privilege:** users and services receive the minimum access required for their role.
- **Need-to-know:** access to sensitive data (PII, accounting records, financial-account data and credentials) is limited to those who require it.
- **Unique identity & accountability:** every person has a unique account; no shared logins.
- **Defense in depth:** application-, database-, and console-level controls reinforce each other.

4. User account lifecycle

- **Provisioning:** accounts are created only with the Policy Owner's authorization, with the least-privileged role appropriate to the person's job.
- **Modification:** when a person's role changes, their access is re-evaluated and adjusted promptly.
- **Deprovisioning:** when a person leaves or no longer needs access, their accounts and sessions are disabled promptly — including the application account and any provider-console access (Supabase, Netlify, GitHub, Plaid, QuickBooks) — and relevant credentials are rotated.

5. Authentication

- **Unique accounts** for all users via Supabase Auth; shared/generic logins are prohibited.
- **Strong credentials:** users set strong, unique passwords; reuse of personal passwords is discouraged. Leaked-password protection is enabled where supported.
- **Multi-factor authentication (MFA) is REQUIRED** for administrators signing in to the WorkTrackPro application — TOTP (authenticator app), enforced at the login gate (a server-side `require\_mfa` setting governs enforcement) — and for every administrative console that can reach production systems or sensitive data: Supabase, Netlify, GitHub, the Plaid dashboard, and the QuickBooks Online

dashboard. Application MFA is available to all users; an administrator can reset a user's MFA if a device is lost.

6. Authorization (least-privilege model)

- **Application RBAC:** access within WorkTrackPro is governed by role — an administrator role and scoped accounting roles — so users see and act only within their authorization.
- **Database Row-Level Security (RLS):** the Supabase database enforces per-role, row-level access rules independently of the application layer.
- **Privileged keys are server-side only:** service-role/admin database keys are used exclusively by trusted server-side functions and are never exposed to browsers. Secret-bearing tables (e.g., stored Plaid/QuickBooks access tokens) are restricted to the service role and are not readable by ordinary authenticated users.
- **Separation of duties** is applied where feasible given the size of the organization.

7. Access to production systems & sensitive data

- Access to production infrastructure (Supabase, Netlify, GitHub) is limited to authorized administrators, protected by MFA.
- Financial-account data and provider access tokens are handled under least privilege: tokens are encrypted, accessible only to server-side functions, and never returned to client applications.
- Physical security of the underlying servers is provided by the Company's cloud providers (Supabase/AWS, Netlify) under their SOC 2 programs; the Company does not operate on-premises production hardware.

8. Access reviews

The Policy Owner reviews who has access to each system and role at least annually, and upon any offboarding or role change, and removes access that is no longer needed. Findings are recorded with the annual risk review.

9. Remote & endpoint access

Users access the systems only from devices that meet the Company's baseline (supported OS with automatic updates, endpoint protection, and screen lock). Where enabled, on-site location enforcement may further restrict shop-floor clock-in to approved locations.

10. Logging & monitoring

Authentication and access events are logged and retained per the Data Retention & Deletion Policy, and are reviewed during security investigations.

11. Enforcement & review

Violations of this policy may result in revoked access and corrective action. This policy is reviewed at least annually and after any material change, and updated as needed by the Policy Owner.

*Document control: maintained by the Policy Owner (Jacob Rough, CEO). Complements the Information

Security Policy. Supersedes all prior versions.*